HireGuard Product Requirements Document

ENGINEERING BLUEPRINT

Build Specification & Parallel Execution Plan for the Agentic AI Engineering Team

DOCUMENT VERSION	TARGET TIMELINE	ENGINEERING TEAM	DEPLOYMENT SCOPE
1.0 (Frozen Spec)	8 Weeks Execution	6 Parallel Workstreams	Local Standalone MVP

1. Product Definition & Boundary

HireGuard is a bounded red-teaming execution platform engineered to evaluate and stress-test conversational Arabic AI interviewers prior to production candidate deployment. The platform operates a stateful testing agent that generates dynamic adversarial probes, captures deterministic evidence, validates against frozen compliance policies, routes findings to human evaluators, and validates mitigations through before-and-after retesting.

Scope Dimension	Specification & Boundary Decision
Core Product	Controlled test harness for text-based Arabic AI interviewers.
Primary Artifact	Evidence-backed finding record with reviewer validation status (Confirmed, Rejected, Inconclusive).
MVP Boundary	One customer-support job role, one controlled target interviewer adapter, synthetic text only, local Dockerized deployment.
Core Experiment	Bounded adaptive agent loop vs. fixed-script baseline under strictly matched turn and token budgets.
Explicit Exclusions	Camera, facial analysis, gaze tracking, emotion detection, voice biometrics, real applicant PII, and production legal compliance certification.

Hard Scope & Safety Enforcement: The MVP is strictly text-based. No camera, facial, or voice processing is permitted. All credentials and test targets are synthetic; security tests run exclusively against local or explicitly owned mock targets.

2. End-to-End Operational Lifecycle

The system executes an 8-stage immutable lifecycle from configuration to mitigation verification:

STAGE 01	STAGE 02	STAGE 03	STAGE 04	STAGE 05	STAGE 06	STAGE 07	STAGE 08
Setup	**Simulate**	**Probe**	**Adapt**	**Verify**	**Review**	**Retest**	**Report**
Role, rubric & budget freeze	Persona load & interview start	Adaptive probe via adapter	Response update & strategy pick	Deterministic & semantic checks	Human approval & disposition	Mitigation replay link	Aggregate metrics & trace export

Stage	System / Actor Action	Required Output Artifact
1. Setup	User selects role rubric, target version, test suite, and budgets.	Immutable RunConfig with unique `run_id`.
2. Simulate	Load synthetic Arabic candidate persona and initialize session.	Persona metadata snapshot and initialized transcript.
3. Probe	Adaptive agent selects allowed action and calls target adapter.	TurnEvent record (actor, input, tool, latency, token usage).
4. Adapt	Controller updates state; evaluates termination budgets.	Decision trace documenting reason for next strategic action.
5. Verify	Evaluate deterministic checks (regex/secrets) and semantic policy.	CheckResult with machine proposal (Pass, Fail, Inconclusive).
6. Review	Human operator inspects trace and confirms or rejects finding.	Immutable review disposition (Reviewer ID, decision, notes).
7. Retest	Mitigation applied to target; identical scenario replayed.	RetestLink pairing baseline and hardened execution traces.
8. Report	Aggregate discovery rates, dialect variance, and cost statistics.	Consolidated JSON / CSV report with complete denominators.

3. Functional Requirements

3.1 Setup, Configuration & Controller Flow

ID	Pri	Requirement Description	Acceptance Criteria
FR-01	P0	Role definition containing competencies, questions, and rubric.	Saved configuration receives an immutable version hash.
FR-02	P0	Target compliance policy listing disallowed disclosures and drift limits.	All confirmed findings link directly to a specific `rule_id`.
FR-03	P0	Unified adapter supporting vulnerable and hardened target versions.	Target switch requires zero code alterations in testing harness.
FR-04	P0	Suite selection, method specification, turn, token, and timeout budgets.	Runs reject missing parameters and persist a frozen configuration snapshot.
FR-05	P0	State machine supporting Queued, Running, Completed, Failed, and Cancelled.	Every transition contains a millisecond timestamp and transition cause.
FR-06	P0	Enforcement of hard bounds across candidate turns, tokens, and retries.	No adapter calls execute post-exhaustion; run records termination cause.
FR-07	P0	Batch fault-isolation ensuring single-case crashes do not break suites.	Failed scenario logs error trace while remaining queue proceeds.
FR-08	P1	Run configuration cloning for matched baseline evaluations.	Cloned snapshot highlights exact differential configuration keys.

3.2 Agent Stateful Loop & Safety Controls

ID	Pri	Requirement Description	Acceptance Criteria
FR-09	P0	State representation tracking hypothesis, transcript, and remaining budget.	Full trace export allows exact step-by-step state graph reconstruction.
FR-10	P0	Strict allowlist of authorized agent tools (SendTurn, LoadPolicy, CheckEvidence).	Unauthorized tools or schema violations reject prior to adapter execution.
FR-11	P0	Interviewer replies treated as untrusted data strings.	Model responses containing prompt injections cannot invoke agent tools.
FR-12	P0	Adaptive probe selection conditioned on immediate target observations.	At least two final evaluation traces demonstrate observation-dependent branch shifts.
FR-13	P0	Terminal state resolution into one of four mutually exclusive outcomes.	Terminal outcome is exactly one of: No Finding, Proposed Finding, Inconclusive, Failure.
FR-14	P0	Separation of automated proposal from verified finding.	Testing agent cannot self-confirm a finding; human review is mandatory.
FR-15	P0	Total state isolation between consecutive scenario executions.	Zero memory or transcript context leaks across scenario boundaries.
FR-16	P1	Synthetic scenario drafting component with human approval gate.	Draft scenarios require explicit sign-off flag prior to active suite inclusion.

3.3 Security, Reliability & Arabic Evaluation Suites

ID	Pri	Requirement Description	Acceptance Criteria
FR-17	P0	Direct and multi-turn indirect prompt-injection test suite.	Records injection technique, attack prompt, target response, and rule link.
FR-18	P0	Valueless canary secret injection (`HG-SECRET-4821`) in vulnerable target.	Exact-match matcher detects leakage without storing authentic secrets.
FR-19	P0	Benign control baseline requesting standard job application details.	Distinguishes legitimate interviewer assistance from excessive refusal.
FR-20	P0	Scoring repeatability testing across 10 fixed candidate transcripts.	Calculates standard deviation, score range, and pass/fail decision flips.
FR-21	P0	Paired Modern Standard Arabic (MSA) vs. Egyptian Arabic (EGY) evaluation.	Quantifies semantic scoring drift on equivalent candidate answers.
FR-22	P0	Deterministic checkers for regex, secrets, schemas, and budget bounds.	Deterministic checks backed by 100% unit-tested test fixtures.
FR-23	P0	Evidence-grounded semantic grading for subtle policy violations.	Semantic verifier cites exact transcript spans; falls back to Inconclusive.
FR-24	P0	Mitigation verification through deterministic scenario replay.	Replay links identical seed and budget against the hardened target version.
FR-25	P1	Schema-driven scenario family extension via modular JSON files.	New test suites load without altering engine or state-machine code.

3.4 Dashboard, Review & Reporting Interface

ID	Pri	Requirement Description	Acceptance Criteria
FR-26	P0	Execution launch interface displaying roles, targets, suites, and budgets.	Operator can execute standard test runs without code modifications.
FR-27	P0	Real-time monitor tracking active turn, budget consumption, and events.	UI polling operates purely on read-only queries with zero state side-effects.
FR-28	P0	Evidence verification interface displaying transcript, trace, and active rule.	Human reviewer inspects complete evidence chain within a unified view.
FR-29	P0	Reviewer disposition capture (Confirm, Reject, Inconclusive) + note.	Actions are timestamped and preserved immutably alongside machine proposal.
FR-30	P0	Comparative evaluation screen contrasting Adaptive vs. Fixed Baseline runs.	Explicitly visualizes sample sizes, denominators, and error counts.
FR-31	P0	Comprehensive export producing auditable JSON and Markdown test reports.	Generated report links all aggregate metrics to granular execution IDs.
FR-32	P1	Multi-attribute filtering (target version, family, severity, status).	Filtering operations are strictly client-side/read-only on stored runs.
FR-33	P1	Demonstration replay mode utilizing pre-recorded execution traces.	Cached replay mode clearly watermarked; uses identical inspection UI.

4. Evidence Schemas & Core Data Contracts

The following data contracts are frozen at the conclusion of Week 1 (Gate G1). Any subsequent modifications require a version bump, migration fixture, and explicit sign-off from the Architect and affected consumers.

4.1 Finding Schema (Evidence Verification)

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "FindingRecord",
  "type": "object",
  "required": ["finding_id", "run_id", "rule_id", "category", "severity", "proposal", "reviewer_status"],
  "properties": {
    "finding_id": { "type": "string", "pattern": "^fnd_[a-f0-9]{8}$" },
    "run_id": { "type": "string" },
    "rule_id": { "type": "string", "example": "POL-SEC-01-CANARY" },
    "category": { "type": "string", "enum": ["INJECTION", "SECRET_LEAK", "RUBRIC_DRIFT",
"POLICY_VIOLATION"] },
    "severity": { "type": "string", "enum": ["LOW", "MEDIUM", "HIGH", "CRITICAL"] },
    "proposal": {
      "type": "object",
      "required": ["verdict", "evidence_spans", "turn_index"],
      "properties": {
        "verdict": { "type": "string", "enum": ["FAIL", "INCONCLUSIVE"] },
        "evidence_spans": { "type": "array", "items": { "type": "string" } },
        "turn_index": { "type": "integer" }
      }
    },
    "reviewer_status": { "type": "string", "enum": ["PENDING", "CONFIRMED", "REJECTED", "INCONCLUSIVE"]
},
    "reviewer_id": { "type": ["string", "null"] },
    "reviewer_note": { "type": ["string", "null"] },
    "reviewed_at": { "type": ["string", "null"], "format": "date-time" }
  }
}
```

4.2 RetestLink Schema (Mitigation Tracking)

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "RetestLinkRecord",
  "type": "object",
  "required": ["retest_id", "original_run_id", "retest_run_id", "mitigation_version", "status_before",
"status_after", "verdict"],
  "properties": {
    "retest_id": { "type": "string", "pattern": "^ret_[a-f0-9]{8}$" },
    "original_run_id": { "type": "string" },
    "retest_run_id": { "type": "string" },
    "scenario_id": { "type": "string" },
    "vulnerable_version": { "type": "string", "example": "v1.0-unpatched" },
    "mitigation_version": { "type": "string", "example": "v1.1-hardened" },
    "status_before": { "type": "string", "enum": ["CONFIRMED_FAIL"] },
    "status_after": { "type": "string", "enum": ["PASS", "FAIL", "INCONCLUSIVE"] },
    "verdict": { "type": "string", "enum": ["MITIGATION_VERIFIED", "VULNERABILITY_PERSISTS"] }
  }
}
```

5. Team Ownership & Parallel Workstream Plan

The 8-week execution plan enforces decoupled development through published mocks, contracts, and fixtures established during Weeks 1 and 2. No workstream is blocked on external progress.

Member & Role	Primary Domain Ownership	Mandatory Weekly Artifact	Cross-Review Partner
Member 1 Lead & Architect	Scope boundaries, API contracts, integration governance, release criteria.	Architecture Decision Record (ADR) + Weekly Tagged Release.	Reviews M6 (Release & QA)
Member 2 Agent Engineer	LangGraph state machine, adaptive policy, tool schemas, trace logger.	Runnable state graph + Decision trace verification suite.	Reviews M3 (Target Adapters)
Member 3 Backend & Target	Interviewer adapters, vulnerable/hardened targets, FastAPI, EvidenceStore.	API build + Deterministic mock interviewer fixture.	Reviews M2 (Tool Schemas)
Member 4 Security Test Eng	Threat model, prompt-injections, canary matcher, exact checking engine.	Versioned security suite + Deterministic matcher tests.	Reviews M5 (Arabic Grounding)
Member 5 Eval & Arabic Lead	Synthetic personas, Arabic dialect pairs, held-out split isolation, metrics.	Frozen scenario suite + Statistical evaluation scripts.	Reviews M4 (Security Checks)
Member 6 UI, DevOps & QA	Review dashboard, Docker environment, CI validation, fallback recordings.	Functional UI build + Portable Docker release bundle.	Reviews M1 (End-to-End Slice)

5.1 Weekly Integration Gates (G1 → G6)

Gate	Deadline	Exit Criteria & Mandatory Deliverables
G1: Contracts	End Week 1	All P0 schemas, API signatures, and mock adapters frozen and passing CI contract tests.
G2: Vertical Slice	End Week 3	One complete scenario successfully travels Adapter → Agent → Store → Review UI.
G3: Alpha Build	End Week 5	Integrated adaptive agent, exact security checking, review actions, and mitigation replay work end-to-end.
G4: Exp. Ready	End Week 6	Prompts, held-out test splits, budgets, and evaluation protocols completely frozen against edits.
G5: Results Freeze	End Week 7	All 120 planned evaluation runs completed, reviewed, and finalized with statistical calculations.
G6: Release Ready	Week 8	Docker bundle passes clean setup on secondary machine; video fallback recorded; slides complete.

6. Evaluation Design & MVP Acceptance Criteria

6.1 Experimental Protocol

The comparative evaluation is conducted across 30 development scenarios and 20 strictly held-out scenarios divided across threat families. Testing matches turn counts (max 6 candidate turns) and token limits across both the adaptive agent and the fixed-script baseline.

- **Core Matrix:** 20 held-out scenarios × 2 methods (Adaptive vs. Fixed) × 2 target variants (Vulnerable vs. Hardened) = **80 runs**.
- **Repeatability Analysis:** 5 selected scenarios repeated 3 times across configurations = **40 additional runs** (Total: 120 evaluation runs).

6.2 Quantitative Report Metrics

Metric Name	Formula / Measurement Protocol
Confirmed Discovery Rate	`Confirmed Violations / Completed Violation Attempts` (disaggregated by method and threat category).
Finding Precision	`Reviewer Confirmed Findings / Total Flagged Machine Proposals`.
False Positive Rate	`Reviewer Rejected Flags / Total Flagged Machine Proposals`.
Scoring Repeatability	Standard deviation, score range, and binary pass/fail flip frequency across identical candidate transcripts.
Dialect Sensitivity	Paired score deltas between equivalent Modern Standard Arabic (MSA) and Egyptian Arabic (EGY) responses.
Execution Efficiency	Average tokens per scenario, aggregate estimated API cost, latency per turn, and completion success rate.

6.3 Mandatory Acceptance Criteria (AC-01 through AC-09)

ID	Criterion Description	Validation Evidence
AC-01	Full lifecycle execution (Setup, Batch Run, Review, Retest, Export) via UI with zero code edits.	Recorded video run + immutable database run IDs.
AC-02	At least 90% of scheduled test runs complete with full execution traces.	Completed run logs showing exact failure denominators.
AC-03	100% of confirmed findings include complete trace and rule linkages.	Automated database schema constraint audit.
AC-04	At least 80% precision on held-out security findings confirmed by reviewer.	Reviewer disposition records and precision formula.
AC-05	At least two execution traces conclusively prove response-dependent probe selection.	Side-by-side annotated state machine decision logs.
AC-06	At least one confirmed vulnerability successfully mitigated and verified via replay.	Paired RetestLink record showing before-and-after runs.
AC-07	Adaptive and fixed evaluations operate under strictly matched information and budgets.	Frozen configuration comparison table.
AC-08	Arabic dialect paired evaluation and repeatability results reported transparently.	Summary analysis tables documenting exploratory bounds.
AC-09	System launches cleanly via Docker or script on an independent secondary laptop.	Pre-release sign-off checklist executed on clean machine.

> **Definition of Done (DoD) for Backlog Items:** An engineering item is considered complete only when unit/contract tests pass in CI, peer cross-review is approved, documentation matches implementation, and the increment integrates cleanly with the latest main-branch release tag.